CISSP Domain 1〜8｜試験直前・暗記カード（全ドメイン版）

> 詳しい解説：分類別・最重要チートシート
> 目的：答案を選ぶための**比較**を、短時間で繰り返し想起する。

① CISSPの答え方（最初の30秒）

事業目標 → 資産と保護要件 → リスク評価 → 統制選択 → 承認 → 運用 → 証拠評価 → 改善。
経営＝リスク受容、オーナー＝要件・権限決定、カストディアン＝実装運用、監査＝独立性・客観性を持つ検証。
人命・安全性を最優先。導入済み≠有効。委託≠責任放棄。ログイン済み≠全操作許可。

② モデル・原則（逆転するものをセットで）

見た瞬間に思い出す条件	反射的に答える
機密性／高位を読めない・低位に書けない	**BLP：No Read Up・No Write Down**
完全性／低位を読めない・高位に書けない	**Biba：No Read Down・No Write Up**
競合A社の秘密を見たら競合B社は不可	**Brewer–Nash / Chinese Wall**
商取引の正規手順・二人承認	**Clark–Wilson：CDI/UDI/TP/IVP**
主体・オブジェクトの権限生成・削除	**Graham–Denning**
権限が漏れる可能性を解析	**HRU**
一人の権限を最小化	Least Privilege
一人で申請・承認を完結させない	Separation of Duties
障害時も安全を維持	Fail Secure
最初から安全に設定	Secure by Default

③ 法律・規格・保証（最重要）

領域	連想
EU個人情報	**GDPR**（目的限定・最小化・削除・説明責任）
米国医療PHI	**HIPAA**
米国金融機関の顧客情報	**GLBA**
米国上場企業の財務報告	**SOX**
米国教育記録／13歳未満のオンライン個人情報	**FERPA／COPPA**
カード会員データの業界基準	**PCI DSS**（法律ではない）
ISMS要求事項／管理策ガイド／リスク管理	**ISO 27001／27002／27005**

領域	連想
BCMS要求事項／システムの継続計画	**ISO 22301／NIST SP 800-34**
NISTの管理策／評価方法／RMF	**800-53／800-53A／800-37**
CSF 2.0の6機能	**Govern–Identify–Protect–Detect–Respond–Recover**
財務報告統制／TSC／一般公開向け	**SOC 1／SOC 2／SOC 3**
時点の設計／期間の運用有効性	**Type 1／Type 2**

④ 数字・公式

- **SLE = AV × EF**、**ALE = SLE × ARO**。資産1000万円、被害40%、2年に1回 → **ALE 200万円／年**。
- **RPO＝過去にどこまで戻るか**、**RTO＝何時間で復旧か**、**WRT＝復旧後の業務再開作業**、**MTD/MAD＝耐えられる最大停止**。
- **Tier I＝基本**、**II＝冗長容量**、**III＝同時保守可能**、**IV＝耐障害**。
- **AES＝128ビットブロック**、**128/192/256ビット鍵**。
- **FAR＝他人を通す**、**FRR＝本人を拒む**。厳しくすると通常FAR↓・FRR↑。

⑤ 技術の取り違えを封じる

質問	答え
ディレクトリ検索／チケット認証	**LDAP／Kerberos**
ネットワークAAA／機器管理AAA	**RADIUS／TACACS+**
API認可の委任／ログイン認証	**OAuth 2.0／OIDC**
XMLアサーションのSSO	**SAML 2.0**
一度のログイン／他組織との信頼関係	**SSO／FIM**
身元証明／認証強度／連携強度	**IAL／AAL／FAL**
ポリシー判断／執行	**PDP／PEP**
所有者裁量／強制ラベル／役職／属性	**DAC／MAC／RBAC／ABAC**
必要な時間だけ／必要な権限だけ	**JIT／JEA**
鍵合意／大量データ暗号／送信者の証明	**(EC)DH／AES／署名**
暗号化しないIPsec／暗号化可能なIPsec	**AH／ESP**
VLAN（L2）／VRF（L3）	**802.1Q／ルーティングテーブル分離**
Wi-Fiの規格／接続ポート認証	**802.11／802.1X**
ログの相関分析／実ユーザー性能計測	**SIEM／RUM**

⑥ ポートの最小セット

SSH 22、DNS 53、HTTP 80、Kerberos 88、HTTPS 443、SMB 445、RDP 3389、LDAP 389、LDAPS 636、RADIUS UDP 1812/1813、TACACS+ TCP 49、IKE UDP 500、NAT-T UDP 4500、L2TP UDP 1701、BGP TCP 179。
ESPはIPプロトコル番号50、AHは51（ポートではない）。

⑦ 監査・テストの場面から答える

問題文	答え
規程・ログ・設定を確認	Examine
現場担当者に手順を聞く	Interview
実際の動作を確かめる	Test
コードを実行せずに解析	SAST
無効入力を与える	Negative Testing
悪用ケースを想定	Misuse Case
定期的に仮想顧客が購入操作	Synthetic Monitoring
実顧客の遅延を観測	RUM
弱点の是正・担当者・期限を管理	POA&M
テスト前に許可範囲と禁止事項を合意	ROE

⑧ Domain 7｜運用・証拠・監視・BCDR（追加暗記）

最短キーワード	即答
誰が証拠を扱った？／改変された？	**Chain of Custody／Hash**
フォレンジック4段階	**収集→検査→分析→報告（NIST 800-86）**
ログ管理／IDS/IPS／ISCM	**NIST 800-92／800-94／800-137**
IDS／IPS／SIEM／SOAR	**検知／遮断／ログ相関／自動対応**
EDR／XDR／UEBA	**端末／領域横断／行動異常**
Threat Hunting／Intelligence	**能動探索／分析済み脅威知見**
Precursor／Indicator／IoC	**発生前の前兆／発生中・後の兆候／具体的な侵害痕跡**
Ingress／Egress／DLP	**入る通信／出る通信／情報持出し防止**
構成／脆弱性／パッチ／変更管理	**正しい構成／弱点評価／更新実行／変更統制**
SoD／Dual Custody／No-Lone	**役割分離／二人で管理／一人で入れない**
封じ込め／根絶／復旧／修復	**広がりを止める／原因除去／業務再開／再発防止**
BIA／BCP／DRP	**重要業務と影響／事業継続／IT復旧**
BCDRの判断	**権限者が発動／SOCはエスカレーション**

最短キーワード	即答
DRPテスト	**読合せ→机上→手順確認→模擬→並行→完全切替**
SAN／NAS	**ブロック／ファイル**
RAID 0／1／5／6／10	**冗長なし／複製／1台／2台／ミラー組を分散**

ISCM（800-137）：定義→確立→実装→分析・報告→対応→見直し。**SIEM**：集約・正規化・相関・安全な保存・分析・報告・リアルタイム監視。**SOAR**：連携→自動化→対応。

NIST 800-61 Rev.2（教材）：準備→検知分析→封じ込め・根絶・復旧→事後活動。**ISO 27035（教材）**：計画準備→検知報告→評価判定→対応→教訓。Rev.3は別の構成。

バックアップ3-2-1：原本込み3コピー、媒体2種類、オフサイト1。**差分＝最後のフル以降／増分＝前回以降。RTO＋WRT ≤ MTD**を目安に設計。**RPO＝許容データ損失の時間幅**。RAID・ミラー・同筐体スナップショット≠独立バックアップ。

ITIL 4：Standard（事前承認）／Normal（リスク別承認）／Emergency（迅速だが統制維持）。**Release＝使える状態にする、Deploy＝環境へ配置。物理センサー**：PIR＝熱変化、Active IR＝ビーム遮断、REX＝退出要求、BMS＝建物設備。**人命と避難が最優先。**

---

⑨ Domain 8｜ソフトウェア開発セキュリティ（追加暗記）

問題文のキーワード	即答・識別ポイント
開発の最初から安全性を確保	**SDLC全工程にセキュリティ統合／Shift Left。**要件→設計→実装→テスト→運用→廃止
リスクを反復ごとに評価・低減	**スパイラルモデル**
迅速な試作／共同要件定義	**RAD／JAD**（JAD＝共同ワークショップ）
ペアプログラミング・TDD	**XP**
開発運用連携／セキュリティもパイプライン統合	**DevOps／DevSecOps**
開発プロセス成熟度／セキュリティ実践成熟度	**SW-CMM／OWASP SAMM**
SW-CMMの5段階	**Initial→Repeatable→Defined→Managed→Optimizing**
ソースを実行せず検査／実行中を外から検査	**SAST／DAST**
実行中に内部観測／実行時に防御	**IAST／RASP**
第三者部品の脆弱性／部品一覧	**SCA／SBOM。**SBOM作成だけでは修正されない
仕様どおりに作ったか／目的に合うか	**Verification／Validation。**独立検証＝**IV&V**
データベース取引の4特性	**ACID＝原子性・一貫性・独立性（分離性）・永続性**

問題文のキーワード	即答・識別ポイント
ソース履歴・変更承認・環境分離	**構成管理／変更管理／SoD**。開発・テスト・本番を分離
ウイルス／ワーム／トロイの木馬	**宿主への感染／自律増殖・伝播／正規ソフトを偽装**
RAT／ボットネット／DDoS	**遠隔操作／感染端末群／分散型サービス拒否攻撃**
論理爆弾／ランサムウェア	**条件成立で発火／暗号化・窃取等で身代金要求**
SQLインジェクション	**パラメータ化クエリ（Prepared Statement）**、最小DB権限
XSS／CSRF	**文脈別出力エンコード・CSP／CSRFトークン・SameSite等**
APIの設計スタイル／安全な通信	**REST＝ステートレス等の制約を持つ設計スタイル／HTTPS（TLS）**
APIキー／OAuth 2.0／OIDC	**識別・呼出し制御の一手段／委任された認可／認証連携**。APIキー単独は強固なユーザー認証ではない
HMAC／SHA-2・SHA-3	**共有秘密鍵でメッセージ完全性・認証／ハッシュ関数**。HMAC自体は暗号化ではない
SDS	**制御のソフトウェア化・集中管理・仮想化・動的なポリシー適用**
SDS革命の6要素	**ID管理／積極的防御／組織的能力向上／俊敏性／細粒度認可／ゼロトラスト**
SDS評価の2問	**システム運用は要件・脅威に適合？／導入した統制は実際に機能？**

Domain 8の一文：「安全な開発手順を組み込み、再利用部品・変更・構成・APIを管理し、稼働後も統制の実効性を検証する」。

---

⑩ 試験終了まで維持したい一文

「何を守るのか、誰に責任があるのか、何がリスクなのか、どんな管理策が適切か、証拠で効いていると確認できるか」。
これを順番に考えれば、単なる技術名の暗記に引きずられにくい。

出典：Domain 1〜7の既存暗記カード、およびDomain 8（8.1〜8.5・SDS）統合マスターノート。